

Lab (เสริม)

IT Infrastructure Security - Definitions and Goals

ความปลอดภัยของโครงสร้างพื้นฐาน (Infrastructure Security) คือการปฏิบัติการและการดำเนินการเพื่อปกป้องโครงสร้างพื้นฐานที่สำคัญจากการโจมตีทางไซเบอร์หรือภัยพิบัติต่างๆ เป้าหมายหลักของความปลอดภัยนี้คือการลดระดับความเสี่ยงที่องค์กรเผชิญอยู่

ระดับความปลอดภัยแบ่งออกเป็นหลายระดับดังนี้:

- **Physical Level**: การป้องกันพื้นที่ทางกายภาพ เช่น ล็อกเกอร์, กล้องวงจรปิด, เครื่องกำเนิดไฟฟ้าสำรอง
- **Network Level**: การเข้ารหัสการรับส่งข้อมูล การใช้ระบบตรวจสอบสิทธิ์
- **Application Level**: การป้องกันข้อมูลในแอปพลิเคชัน เช่น การสร้างระบบป้องกัน SQL injections
- **Data Level**: การปกป้องข้อมูลที่ถูกเก็บรักษาในสถานที่ต่างๆ

Log and Logging System

Log (บันทึกเหตุการณ์) คือข้อมูลที่บันทึกเหตุการณ์ต่างๆ ที่เกิดขึ้นภายในระบบหรือเครือข่ายขององค์กร โดยแต่ละรายการในบันทึกจะมีข้อมูลเฉพาะเกี่ยวกับเหตุการณ์ที่เกิดขึ้นในระบบนั้น

บันทึกเหตุการณ์สามารถประกอบด้วยข้อมูลประเภทต่างๆ ได้แก่:

- **Security Software Logs**:
  - ข้อมูลด้านความปลอดภัยของคอมพิวเตอร์ เช่น Anti-malware, IDS/IPS, VPN, Proxy, ระบบตรวจสอบความปลอดภัย, การยืนยันตัวตน, เราเตอร์, ไฟร์วอลล์
- **Operating System Logs**:
  - ข้อมูลเหตุการณ์ในระบบ เช่น เหตุการณ์ของระบบ (System Events) และบันทึกการตรวจสอบ (Audit Records)
- **Application Logs**:
  - ข้อมูลจากแอปพลิเคชัน เช่น คำขอของลูกค้าและการตอบสนองของเซิร์ฟเวอร์ ข้อมูลบัญชี การใช้งานระบบ
- ระบบบันทึกความปลอดภัยของคอมพิวเตอร์ถูกสร้างขึ้นจากหลายแหล่ง เช่น ซอฟต์แวร์รักษาความปลอดภัย ไฟร์วอลล์ ระบบตรวจจับการบุกรุกและป้องกัน (IDS/IPS) ระบบปฏิบัติการบนเซิร์ฟเวอร์ เวิร์กสเตชัน และอุปกรณ์เครือข่าย รวมถึงแอปพลิเคชัน

- แหล่งบันทึกข้อมูลส่วนใหญ่ทำงานอย่างต่อเนื่อง ทำให้สร้างรายการบันทึกอย่างต่อเนื่อง (เหมือนกับข้อมูลแบบ time series)
- บางแหล่งทำงานเป็นระยะ ๆ ทำให้สร้างรายการบันทึกเป็นชุด ๆ ที่ช่วงเวลาสม่ำเสมอ
- จำนวน ปริมาณ และความหลากหลายของบันทึกความปลอดภัยของคอมพิวเตอร์เพิ่มขึ้นมาก จึงจำเป็นต้องมีการจัดการบันทึกความปลอดภัยอย่างเป็นระบบ

Needs for Log Management

การจัดการ log เป็นสิ่งสำคัญในการเก็บบันทึกความปลอดภัยของคอมพิวเตอร์ให้เพียงพอในระยะเวลาที่เหมาะสม นอกจากประโยชน์ในการจัดการล็อกแล้ว ยังมีข้อบังคับและกฎหมายหลายฉบับที่บังคับให้องค์กรต้องจัดเก็บและตรวจสอบล็อกบางประเภท เช่น

- **FISMA (2002)**: กฎหมายจัดการข้อมูลของรัฐบาลกลางสหรัฐ
- **GLBA**: กฎหมายความเป็นส่วนตัวสำหรับธุรกรรมการเงิน
- **HIPAA (1996)**: กฎหมายคุ้มครองข้อมูลทางการแพทย์
- **SOX (2002)**: กฎหมายควบคุมทางการเงินของบริษัทในสหรัฐฯ
- **PCI DSS**: มาตรฐานความปลอดภัยของข้อมูลบัตรเครดิต

Log Management

Challenges in Log Management

- **Log Generation and Storage:**
  - มีแหล่ง log หลายแหล่ง
  - เนื้อหา log ที่ไม่สอดคล้องกัน
  - เวลา (timestamps) ที่ไม่สอดคล้องกัน
  - รูปแบบ log ที่ไม่สอดคล้องกัน
- **Log Protection:** การป้องกันล็อกจากการเข้าถึงที่ไม่เหมาะสม
- **Log Analysis:** การวิเคราะห์ log เพื่อสืบค้นข้อมูลสำคัญ

Possible Solutions

- ให้ความสำคัญกับการจัดการ log ในทุกส่วนขององค์กร
- จัดตั้งนโยบายและกระบวนการสำหรับการจัดการ log
- สร้างและรักษาโครงสร้างการจัดการ log ที่ปลอดภัย
- จัดเตรียมการสนับสนุนที่เพียงพอให้แก่พนักงานที่รับผิดชอบจัดการ log

Log Management Infrastructure

Architecture - Comprises Three Tiers:

1. **Log Generation:** การสร้างlog จากเหตุการณ์ต่าง ๆ ในระบบ
2. **Log Analysis and Storage:** การวิเคราะห์และเก็บรักษา log
3. **Log Monitoring:** การตรวจสอบล็อกเพื่อหาข้อมูลสำคัญ

Common Log Management Infrastructure Functions:

- **General:** การจัดการ log ทั่วไป เช่น การแยกล็อก การกรองเหตุการณ์ การรวมข้อมูลจากเหตุการณ์ต่าง ๆ (event aggregation)
- **Storage:** การจัดเก็บ เช่น การหมุนเวียน log การเก็บถาวร การบีบอัด การลดขนาด และการตรวจสอบความสมบูรณ์ของไฟล์ log
- **Analysis:** การวิเคราะห์เหตุการณ์ การตรวจสอบ การรายงานข้อมูลจาก log
- **Disposal:** การลบ log

Syslog-Based Centralized Logging Software

ระบบการจัดเก็บล็อกแบบรวมศูนย์ที่ใช้ Syslog เป็นมาตรฐานในการสร้างและจัดการล็อก โดยแต่ละเครื่องที่สร้างล็อกจะใช้รูปแบบที่เหมือนกันในการส่งข้อมูลไปยังเซิร์ฟเวอร์ Syslog ตัวกลาง ทำให้การเก็บและส่งข้อมูลล็อกเป็นไปอย่างง่ายดาย

- **Syslog** เป็น framework ที่ช่วยในการสร้างล็อก เก็บรักษาล็อก และถ่ายโอนล็อก ที่สามารถใช้ได้กับระบบปฏิบัติการ (OS) หรือซอฟต์แวร์ด้านความปลอดภัยต่าง ๆ
- **รูปแบบของ Syslog**: ประกอบด้วย
  - **Message Type (Facility):** ระบุประเภทของข้อความ เช่น kernel messages, mail system messages
  - **Severity:** ระบุระดับความรุนแรงของข้อความ ตั้งแต่ 0 (ฉุกเฉิน) ถึง 7 (debug)

Syslog Format



การสร้างข้อความ Syslog ถูกออกแบบมาให้เรียบง่าย โดยแต่ละข้อความจะประกอบด้วย 3 ส่วนหลัก:

1. **ส่วนแรก**: ระบุ Facility และ Severity โดยแสดงเป็นค่าตัวเลข
2. **ส่วนที่สอง**: ข้อมูลเกี่ยวกับเวลา (Timestamp) และชื่อโฮสต์ (Hostname) หรือที่อยู่ IP ของแหล่งที่สร้างล็อก
3. **ส่วนที่สาม**: เนื้อหาของข้อความล็อกจริง ๆ

ปัญหาที่เกิดขึ้น:

- ไม่มีฟิลด์มาตรฐานในเนื้อหาข้อความ จึงยากต่อการแปลงข้อมูลให้เครื่องอ่านได้ (Machine-parseable)
- ความหลากหลายของรูปแบบข้อความทำให้โปรแกรมวิเคราะห์ต้องเข้าใจรูปแบบต่าง ๆ เพื่อนำข้อมูลไปใช้

Syslog Security

ในช่วงที่ Syslog ถูกพัฒนาขึ้น ความปลอดภัยของ log ไม่ได้ถูกพิจารณาเป็นเรื่องสำคัญมากนัก และการนำไปใช้งานส่วนใหญ่จะใช้โปรโตคอล UDP ซึ่งไม่มีการเชื่อมต่อและไม่เสถียรในการถ่ายโอน log ระหว่างโฮสต์

อย่างไรก็ตาม มีการเสนอ RFC 3195 เพื่อปรับปรุงความปลอดภัยของ Syslog โดยมีฟีเจอร์สำคัญที่ช่วยเพิ่มความมั่นคงปลอดภัย (C/I/A):

- **Reliable Log Delivery**: ส่งมอบ log ได้อย่างเชื่อถือ
- **Transmission Confidentiality Protection**: ปกป้องความลับของข้อมูลขณะส่ง
- **Transmission Integrity Protection and Authentication**: ปกป้องความถูกต้องของข้อมูลและการพิสูจน์ตัวตน

ฟีเจอร์เพิ่มเติมที่ไม่ได้ขึ้นกับ RFC 3195 ที่มักพบใน Syslog บางระบบ:

- **Robust Filtering**: การกรอง log ที่มีประสิทธิภาพสูง
- **Log Analysis**: การวิเคราะห์ log
- **Event Response**: การตอบสนองต่อเหตุการณ์
- **Alternative Message Formats**: รูปแบบข้อความอื่น ๆ
- **Log File Encryption**: การเข้ารหัสไฟล์ log
- **Database Storage for Logs**: การเก็บ log ในฐานข้อมูล
- **Rate Limiting**: การจำกัดอัตรา

Additional Types of Log Management Software

Security Information and Event Management Software (SIEM)

ซอฟต์แวร์ SIEM เป็นซอฟต์แวร์การจัดการการล็อกแบบรวมศูนย์ ที่พัฒนาขึ้นจาก Syslog โดย SIEM สามารถวิเคราะห์ log และเก็บข้อมูล log ไว้ในฐานข้อมูล ซึ่งช่วยในการติดตามและตรวจสอบเหตุการณ์ด้านความปลอดภัยของระบบ

ฟีเจอร์ของ SIEM มีการรวบรวม log จากแหล่งข้อมูลได้สองวิธีหลัก:

- **Agentless**: ไม่ต้องติดตั้งซอฟต์แวร์เพิ่มเติมในระบบ
- **Agent-Based**: ต้องติดตั้งซอฟต์แวร์ในระบบเพื่อเก็บ log

ฟีเจอร์ของ SIEM ได้แก่:

- **GUI**: อินเทอร์เฟซที่ใช้งานง่าย
- **Incident tracking and reporting**: การติดตามเหตุการณ์และการรายงาน
- **Asset information storage**: การจัดเก็บข้อมูลทรัพย์สิน

Log Management Planning and Operational Processes

- **Planning**:
    - Define Roles and Responsibilities (P.39/72)

      การวางแผนการจัดการบันทึก (Log Management Planning): บทบาทและหน้าที่

        1. **ผู้ดูแลระบบและเครือข่าย (System and network administrators)**:
            - รับผิดชอบการกำหนดค่า (configuring) การบันทึกในระบบและอุปกรณ์เครือข่าย การวิเคราะห์บันทึกเป็นระยะๆ รายงานกิจกรรมการจัดการบันทึก และการบำรุงรักษาบันทึกและซอฟต์แวร์บันทึก
        2. **ผู้ดูแลความปลอดภัย (Security administrators)**:
            - จัดการและเฝ้าติดตามโครงสร้างพื้นฐานการจัดการบันทึก กำหนดค่าการบันทึกในอุปกรณ์ความปลอดภัย (เช่น firewalls, IDS) และช่วยในการวิเคราะห์บันทึก
        3. **ทีมตอบสนองต่อเหตุการณ์ความปลอดภัย (Computer security incident response teams)**:

- ใช้ข้อมูลจากบันทึกเพื่อตอบสนองต่อเหตุการณ์ความปลอดภัย

4. **นักพัฒนาแอปพลิเคชัน (Application developers)**:
    - ออกแบบหรือปรับแต่งแอปพลิเคชันเพื่อให้มั่นใจว่ามีการบันทึกตามข้อกำหนด
5. **เจ้าหน้าที่ความปลอดภัยสารสนเทศ (Information security officers)**:
    - ดูแลโครงสร้างพื้นฐานการจัดการบันทึก
6. **ประธานเจ้าหน้าที่ข้อมูล (CIO)**:
    - ดูแลทรัพยากรด้าน IT ที่รับผิดชอบในการสร้าง ส่งต่อ และจัดเก็บบันทึก
7. **ผู้ตรวจสอบ (Auditors)**:
    - ใช้ข้อมูลบันทึกในการตรวจสอบ
8. **บุคลากรจัดซื้อ (Procurement staff)**:
    - เกี่ยวข้องกับการจัดหาซอฟต์แวร์ที่สามารถสร้างหรือจัดการบันทึก

- Establish Logging Policies

  การสร้างนโยบายการล็อกในองค์กรจำเป็นต้องมีการกำหนดความต้องการและเป้าหมายที่ชัดเจนสำหรับการล็อกและการตรวจสอบการล็อก การจัดการนั้นควรคำนึงถึงข้อกำหนดทางกฎหมาย ระเบียบข้อบังคับ และนโยบายขององค์กร รวมถึงนโยบายการเก็บรักษาข้อมูล (data retention policies) นอกจากนี้ยังมีการเน้นย้ำถึงการบริหารจัดการการลดความเสี่ยงควบคู่กับทรัพยากรและเวลาในการจัดการล็อกอย่างเหมาะสม

  สรุปใจความสำคัญ:

  1. องค์กรควรพัฒนานโยบายที่กำหนดข้อกำหนดที่จำเป็นอย่างชัดเจน เช่น
     - ประเภทของโฮสต์หรืออุปกรณ์ที่ควรทำการล็อก
     - ประเภทของเหตุการณ์ที่ควรบันทึก (เช่นเหตุการณ์ด้านความปลอดภัย การเชื่อมต่อเครือข่าย)
     - ลักษณะข้อมูลที่ควรล็อก เช่น การบันทึกชื่อผู้ใช้และที่อยู่ IP
     - ความถี่ในการล็อกเหตุการณ์และการถ่ายโอนข้อมูลล็อก
  2. ต้องคำนึงถึงการจัดเก็บและการวิเคราะห์ข้อมูลล็อกอย่างเป็นระบบ รวมถึงการรักษาความลับ ความสมบูรณ์ และความพร้อมใช้งานของข้อมูลล็อก

- **Operational Processes**:
  - กำหนดแหล่งที่มาของ log (P.49/72)
    - การสร้าง log การจัดเก็บ log และการทำลาย log รวมถึงการรักษาความปลอดภัยของ log
    - โดยผู้ดูแลระบบต้องกำหนดค่าว่าจะทำการเก็บข้อมูลอะไร ที่ไหน และจะเก็บไว้เป็นระยะเวลานานแค่ไหน ซึ่งขั้นตอนนี้มีความซับซ้อน เนื่องจากต้องพิจารณาจากนโยบายขององค์กร เช่น โฮสต์ไหนที่ควรล็อก ข้อมูลที่ควรล็อก รวมถึงข้อมูลใดที่ควรบันทึก

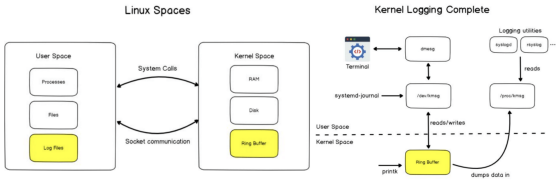
      สรุปใจความสำคัญ:

      1. ผู้ดูแลระบบต้องพิจารณาว่าโฮสต์ใดควรมีส่วนร่วมในการจัดการล็อกและเลือกแหล่งที่มาของล็อกที่เกี่ยวข้อง
      2. ต้องพิจารณาว่าจะบันทึกเหตุการณ์ประเภทใดและลักษณะข้อมูลใดควรเก็บไว้
      3. การกำหนดค่าล็อกอาจขึ้นอยู่กับความสามารถของแหล่งล็อก บางแหล่งสามารถปรับแต่งได้อย่างละเอียด ในขณะที่บางแหล่งสามารถเปิดหรือปิดการล็อกได้เท่านั้น
  - การวิเคราะห์ข้อมูล log

- ตอบสนองต่อเหตุการณ์ที่ระบุไว้
- การจัดการการเก็บข้อมูล log ระยะยาว

Linux Logging Type

- **Kernel Logging:** เกี่ยวข้องกับการล็อกข้อผิดพลาด, การเตือน หรือข้อมูลต่าง ๆ ที่ Kernel อาจสร้างขึ้น
  - ข้อมูลเหล่านี้ถูกบันทึกไว้ใน Kernel Space
  - สามารถดูข้อมูลเหล่านี้ได้โดยใช้คำสั่ง `dmesg`
- **User Logging:** เกี่ยวข้องกับการล็อกที่เชื่อมโยงกับ User Space ซึ่งเป็นการล็อกข้อมูลของกระบวนการหรือบริการที่ทำงานบนเครื่องแม่ข่าย



- แสดงให้เห็นการเชื่อมต่อระหว่าง User Space กับ Kernel Space โดยการเรียกใช้ System Calls และ Socket Communication
- ในส่วนของ Kernel Space มี Ring Buffer สำหรับบันทึกข้อมูลที่เกี่ยวข้อง
- กระบวนการอ่านและเขียนข้อมูลใน Ring Buffer ถูกจัดการโดยใช้คำสั่ง `printk` และบันทึกลงในไฟล์ล็อก (log files) ที่กำหนด

User Side Logging

มีความแตกต่างจากการล็อกในฝั่ง Kernel โดยฝั่งผู้ใช้ใช้โปรโตคอล **Syslog** สำหรับการสร้าง ส่งต่อ และเก็บรวบรวมล็อกที่ผลิตขึ้นบนระบบปฏิบัติการ Linux

- **Syslog** ถูกใช้เป็นมาตรฐานในการล็อกข้อมูลบนระบบ Linux
- Syslog กำหนดระดับความรุนแรง (Severity Levels) และระดับสิ่งอำนวยความสะดวก (Facility Levels) เพื่อช่วยให้ผู้ใช้สามารถเข้าใจความสำคัญของล็อกได้ดียิ่งขึ้น
- ข้อมูลล็อกสามารถนำไปวิเคราะห์และแสดงผลบนเซิร์ฟเวอร์ที่เรียกว่า **Syslog Servers**

Syslog Facilities (แหล่งที่มาของข้อความ):

อธิบายถึงแหล่งข้อมูลที่ล็อกข้อความ (Numerical Code แทนแหล่งข้อมูลประเภทต่าง ๆ) เช่น:

- `0 - kern`: Kernel messages (ข้อความจากเคอร์เนล)
- `1 - user`: User-level messages (ข้อความจากผู้ใช้)
- `2 - mail`: Mail system (ระบบอีเมล)
- `3 - daemon`: System Daemons (บริการของระบบ)
- `4 - auth`: Security messages (ข้อความด้านความปลอดภัย)
- `5 - syslog`: Syslogd messages (ข้อความจาก Syslogd)
- `6 - lpr`: Line printer subsystem (ระบบพิมพ์)

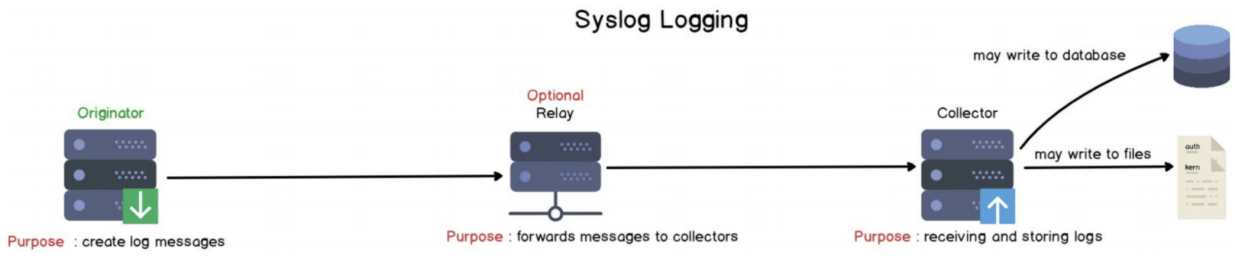
- `7 - news` : Network news subsystem (ระบบข่าวสารเครือข่าย)
- `8 - uucp` : UUCP subsystem (ระบบ UUCP)
- `9 - cron` : Clock daemon (โปรแกรมจัดการเวลา)
- `10 - authpriv` : Security messages (ข้อความด้านความปลอดภัย)
- `11 - ftp` : FTP daemon (ระบบ FTP)
- `12 - ntp` : NTP subsystem (ระบบเวลา NTP)
- `13 - security` : Security log audit (ตรวจสอบบันทึกความปลอดภัย)
- `14 - console` : Console log alerts (การแจ้งเตือนจากคอนโซล)
- `15 - solaris-cron` : Scheduling logs (บันทึกการตั้งเวลา)
- `16-23 - local0 ถึง local7` : Locally used facilities (แหล่งใช้งานในพื้นที่)

Syslog Severity Levels (ระดับความรุนแรง):

อธิบายระดับความรุนแรงของเหตุการณ์ที่ถูกบันทึก เช่น:

- `0 - Emergency (emerg)` : สถานการณ์ฉุกเฉินที่อาจทำให้ระบบใช้งานไม่ได้
- `1 - Alert (alert)` : เหตุการณ์ที่ต้องแก้ไขทันที เช่น การล้มเหลวของฮาร์ดแวร์
- `2 - Critical (crit)` : ข้อผิดพลาดที่รุนแรง เช่น การล้มเหลวของซอฟต์แวร์สำคัญ
- `3 - Error (err)` : ข้อผิดพลาดที่เกิดขึ้น แต่ไม่ถึงกับทำให้ระบบล้มเหลว
- `4 - Warning (warning)` : การเตือนถึงความเสี่ยงที่ยังไม่เป็นข้อผิดพลาดร้ายแรง
- `5 - Notice (notice)` : เหตุการณ์ปกติที่ต้องรับทราบ
- `6 - Informational (info)` : ข้อมูลทั่วไปเกี่ยวกับเหตุการณ์ต่าง ๆ ในระบบ
- `7 - Debug (debug)` : ข้อความที่ใช้ในการดีบักเพื่อช่วยในการพัฒนาระบบ

Syslog Architecture

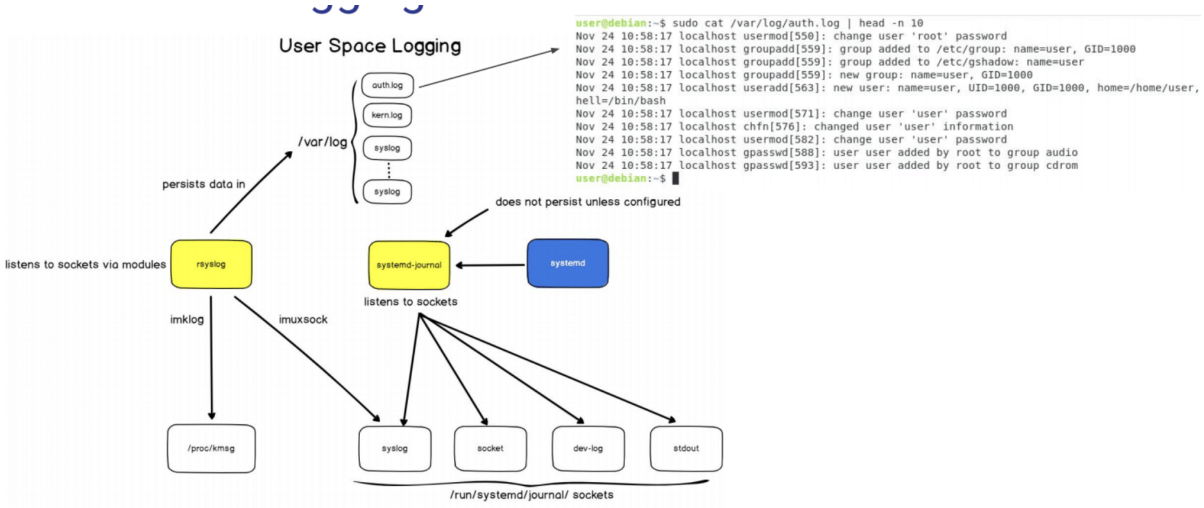


แบ่งออกเป็นส่วนต่าง ๆ ดังนี้:

1. **Originator (Syslog Client)**: เป็นผู้สร้างข้อความล็อก และส่งข้อความที่ฟอร์แมตตาม Syslog ไปยังเครือข่ายหรือแอปพลิเคชันที่ถูกต้อง
2. **Relay** (Optional): ทำหน้าที่ส่งต่อข้อความผ่านเครือข่ายและสามารถเพิ่มข้อมูลเพิ่มเติมลงในข้อความ ตัวอย่างเช่น การใช้ Logstash หรือ Fluentd

3. **Collector (Syslog Server)**: รับและเก็บบันทึกล็อกจากหลาย ๆ แอปพลิเคชัน และนำไปเก็บยังปลายทาง เช่น ไฟล์ท้องถิ่น, ฐานข้อมูล, หรือแคช

Linux Local Logging Architecture



เกี่ยวข้องกับการจัดการบันทึกข้อมูล (Logging) บนระบบ Linux โดยใช้การแบ่งพื้นที่ดังนี้:

- **User Space Logging**: การบันทึกที่เกิดขึ้นจากกระบวนการใน User Space ข้อมูลจะถูกส่งผ่าน Syslog และ systemd-journal เพื่อจัดการและบันทึกข้อมูลในไดเรกทอรี `/var/log`
- **rsyslog และ systemd-journal**: ทำหน้าที่เป็นตัวเก็บบันทึกข้อมูลจากแหล่งข้อมูลต่าง ๆ ผ่านโมดูล เช่น imuxsock, syslog, และ socket แล้วจัดเก็บลงในไฟล์หรือหน่วยความจำ
- **systemd**: ใช้สำหรับบันทึกและจัดการข้อมูลแบบ Real-Time บนเซอร์วิสต่าง ๆ ของระบบ Linux

จุดสำคัญคือ Log ที่ถูกสร้างจาก User Space จะถูกส่งไปยัง Socket และบันทึกในไดเรกทอรี `/var/log` ซึ่งทำให้ผู้ใช้สามารถตรวจสอบและวิเคราะห์ Log ได้

Rsyslog และ Systemd-Journal

มีความแตกต่างหลักดังนี้:

- **Rsyslog**:
  - ทำหน้าที่เก็บบันทึกข้อมูล (Logs) ลงในไฟล์ที่เก็บไว้ใน `/var/log`
  - ไฟล์กำหนดค่าอยู่ที่ `/etc/rsyslog.conf`
  - สามารถกำหนดกฎการจัดการบันทึกข้อมูลได้ที่ `/etc/rsyslog.d/*.conf`
  - โมดูลที่เปิดใช้งานโดยค่าเริ่มต้นคือ `imuxsock` (สำหรับการบันทึกท้องถิ่น) และ `imjournal` (สำหรับการส่งข้อมูลจาก journal ไปยัง rsyslog)
- **Systemd-Journal**:
  - จะไม่บันทึกข้อมูลเว้นแต่ว่าจะกำหนดให้ทำ
  - ไฟล์กำหนดค่าอยู่ที่ `/etc/systemd/journald.conf`
  - เก็บบันทึกในรูปแบบไบนารีในไดเรกทอรี `/run/log/journal`

- การดูบันทึกต้องใช้คำสั่ง `journalctl` เช่น `journalctl -r` เพื่อดูบันทึกล่าสุด หรือใช้คำสั่ง `journalctl -u <service>`

Review for Some Attacks

การโจมตีด้วยมัลแวร์ (Malware)

- **แพร่กระจาย**:
  - ต้องพึ่งพาพาหะ (เช่น Executable Files, Boot Sector, Script-Enabled Text Files)
  - หรือไม่พึ่งพาพาหะก็ได้ โดยแพร่ผ่านช่องโหว่ในซอฟต์แวร์ มนุษย์ หรือเครือข่าย
- **การเน้นโจมตี Target**:
  - โจมตีวัตถุประสงค์ที่กำหนด เช่น การทำให้ข้อมูลเสียหาย (System/Data Corruption)
  - การเปิดเผย/รั่วไหลของข้อมูล (Information Disclosure/Leakage/Breach)
  - ใช้ Botnets หรือการกระทำอื่นๆ ตามวัตถุประสงค์

การโจมตีแบบ DoS/DDoS

- **การโจมตีโดยใช้ทรัพยากรจนหมด** (Resource Exhaustion Attack)
- **การโจมตีจากช่องโหว่ในระบบ** (Bug/Vulnerability Attack) เช่น การใช้ประโยชน์จากจุดอ่อนของเป้าหมาย

มาตรการควบคุมด้านความปลอดภัย:

- ป้องกัน (Prevent), ตรวจจับ (Detect), ระบุ (Identify), แก้ไข (Correct), ฟื้นฟู (Recovery)

Cyber Kill Chain - สรุป

Cyber Kill Chain เป็นโมเดลที่แสดงถึงขั้นตอนต่างๆ ในการโจมตีทางไซเบอร์ พัฒนาโดย Lockheed Martin ภายใต้กรอบการป้องกันที่เน้นการใช้ข้อมูลข่าวกรอง (Intelligence Driven Defense) เพื่อระบุและป้องกันการแทรกซึมจากการโจมตีไซเบอร์

ขั้นตอนใน Cyber Kill Chain

1. **Reconnaissance** (สอดแนม): เก็บข้อมูลเป้าหมาย เช่น ที่อยู่อีเมล และข้อมูลการประชุม
2. **Weaponization** (สร้างอาวุธ): รวมการใช้ช่องโหว่กับ backdoor เพื่อสร้าง payload
3. **Delivery** (ส่งมอบ): ส่ง payload ที่สร้างขึ้นไปยังเหยื่อผ่านอีเมล เว็บ หรือ USB
4. **Exploitation** (ใช้ประโยชน์): ใช้ช่องโหว่ในการรันโค้ดที่ระบบของเหยื่อ
5. **Installation** (ติดตั้ง): ติดตั้งมัลแวร์ในอุปกรณ์ที่เป็นเป้าหมาย
6. **Command & Control (C2)**: สร้างช่องทางควบคุมเหยื่อจากระยะไกล
7. **Actions on Objectives** (ทำตามเป้าหมาย): บรรลุเป้าหมายของการโจมตี เช่น ขโมยข้อมูล

Reconnaissance - สรุป

Reconnaissance หรือการสอดแนม คือขั้นตอนเริ่มต้นใน Cyber Kill Chain เพื่อรวบรวมข้อมูลเกี่ยวกับเป้าหมาย มีสองรูปแบบ:

- **Passive**: รอรับข้อมูลที่ถูกเปิดเผยเอง เช่น ข้อมูลที่เปิดเผยในสาธารณะ
- **Active**: การกระทำที่ชัดเจนในการแสวงหาข้อมูล เช่น การส่ง Probe หรือ Request เพื่อเก็บ Response

เป้าหมายของ Reconnaissance:

- รวบรวมข้อมูล (Information Gathering/Collection)
- การสแกนเครือข่ายหรือพอร์ต (Network/Port Scanning)
- การทำรายการ Host/Service (Host/Service Enumeration)
- การทำแผนที่เครือข่าย/ระบบ (Network/System Mapping)

Performing Network Reconnaissance

Reconnaissance ในเครือข่ายคือขั้นตอนสำคัญในการเจาะระบบ โดยใช้เครื่องมือแบบ passive และ active เพื่อลดโอกาสการถูกตรวจจับ

เครื่องมือสำหรับ passive reconnaissance:

1. **Wireshark**
2. **Google**
3. **FindSubDomains.com**
4. **VirusTotal**
5. **Shodan**

เครื่องมือสำหรับ active reconnaissance:

1. **Nmap**
2. **Nessus**
3. **OpenVAS**
4. **Nikto**
5. **Metasploit**

Passive reconnaissance จะไม่ทำงานร่วมกับระบบโดยตรง ขณะที่ active reconnaissance จะมีความเสี่ยงในการถูกตรวจพบ

Top Passive Recon Tools

1. **Wireshark**: ใช้ในการวิเคราะห์การจราจรของเครือข่าย ทำให้ผู้โจมตีสามารถเก็บข้อมูลการจราจรของระบบเป้าหมายได้ ซึ่งอาจเปิดเผย IP และข้อมูลอื่น ๆ ที่สามารถระบุถึงซอฟต์แวร์ที่มีความเสี่ยงได้
2. **Google**: สามารถใช้เพื่อรวบรวมข้อมูลที่เปิดเผยทางสาธารณะเกี่ยวกับองค์กร เช่น หน้าที่ของเว็บไซต์ ซึ่งอาจเปิดเผยระบบที่ใช้อยู่ภายในเครือข่ายขององค์กร
3. **FindSubDomains.com**: ช่วยในการค้นหาเว็บไซต์ที่เกี่ยวข้องกับองค์กรและข้อมูลที่ไม่ได้ตั้งใจเปิดเผยทางอินเทอร์เน็ต
4. **VirusTotal**: อนุญาตให้ผู้ใช้สามารถอัปโหลดไฟล์หรือ URL เพื่อวิเคราะห์ว่าเป็นไฟล์ที่เป็นอันตรายหรือไม่ ข้อมูลที่ได้รับจาก VirusTotal อาจช่วยเปิดเผยข้อมูลภายในที่สำคัญขององค์กร
5. **Shodan**: เครื่องมือค้นหาอุปกรณ์ที่เชื่อมต่อกับอินเทอร์เน็ต ผู้โจมตีสามารถใช้ Shodan ในการค้นหาอุปกรณ์ที่มีความเสี่ยง

Top Active Recon Tools

1. **Nmap**: เครื่องมือสแกนเครือข่าย ใช้ในการระบุรายละเอียดของระบบและโปรแกรมที่ทำงานอยู่โดยการสแกน IP หรือระบบเพื่อดึงข้อมูลเครือข่ายเป้าหมาย
2. **Nessus**: เครื่องสแกนความเปราะบางในระบบเชิงพาณิชย์ ระบุแอปพลิเคชันที่มีความเสี่ยงและอาจถูกโจมตีได้
3. **OpenVAS**: เครื่องสแกนความเปราะบางแบบโอเพนซอร์ส ซึ่งมีฟังก์ชันคล้ายกับ Nessus
4. **Nikto**: เครื่องมือสแกนความเปราะบางของเว็บเซิร์ฟเวอร์ ตรวจหาช่องโหว่ต่างๆ
5. **Metasploit**: ชุดเครื่องมือการโจมตีที่รวมการใช้ประโยชน์จากช่องโหว่ต่างๆ